Zadanie 2 - SQL Injection Aplikacia

Čeč Lukáš

Použité technológie

Frontend - React (JavaScript, Vite)

Backend - Python, FastAPI, knižnica psycopg2 na pripojenie k databáze

Databáza - PostgreSQL

Spustenie a kontajnerizácia - Docker a docker compose (tri kontajneri: db, backend, frontend)

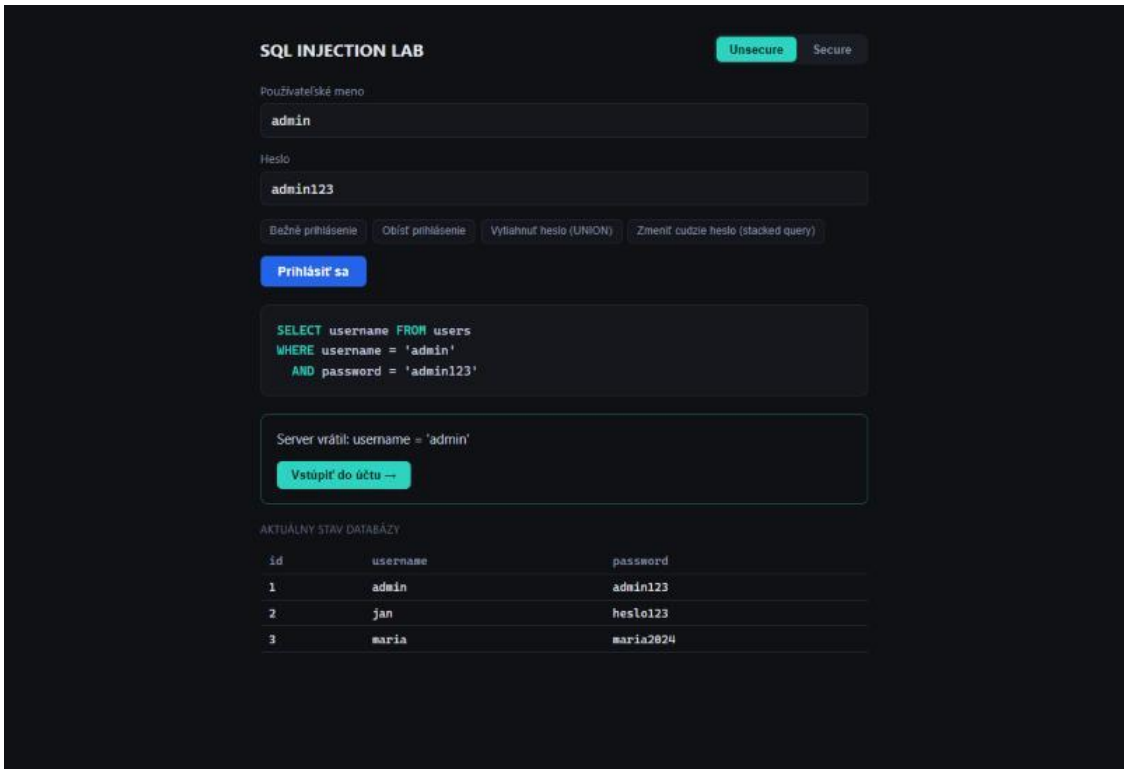
Spustenie aplikácie

Aplikácia pozostáva z frontendu v Reacte, backendu vo FastAPI a databázy PostgreSQL. Spušta sa príkazom docker compose up --build, čím sa vytvoria tri kontajneri - db, backend a frontend. Frontend beží na http://localhost:5173 a backend na http://localhost:8000.

V aplikácii je jeden prihlasovací formulár (username + password) a prepínač Secure / Unsecure. V unsecure režime backend skladá SQL dotaz priamym vkladaním vstupu do reťazca, v secure režime používa parametrizovaný dotaz. Pod formulárom je vždy vidno presný SQL dotaz, ktorý sa posiela, a po odoslaní aj aktuálny stav celej databázy.

Bežné prihlásenie

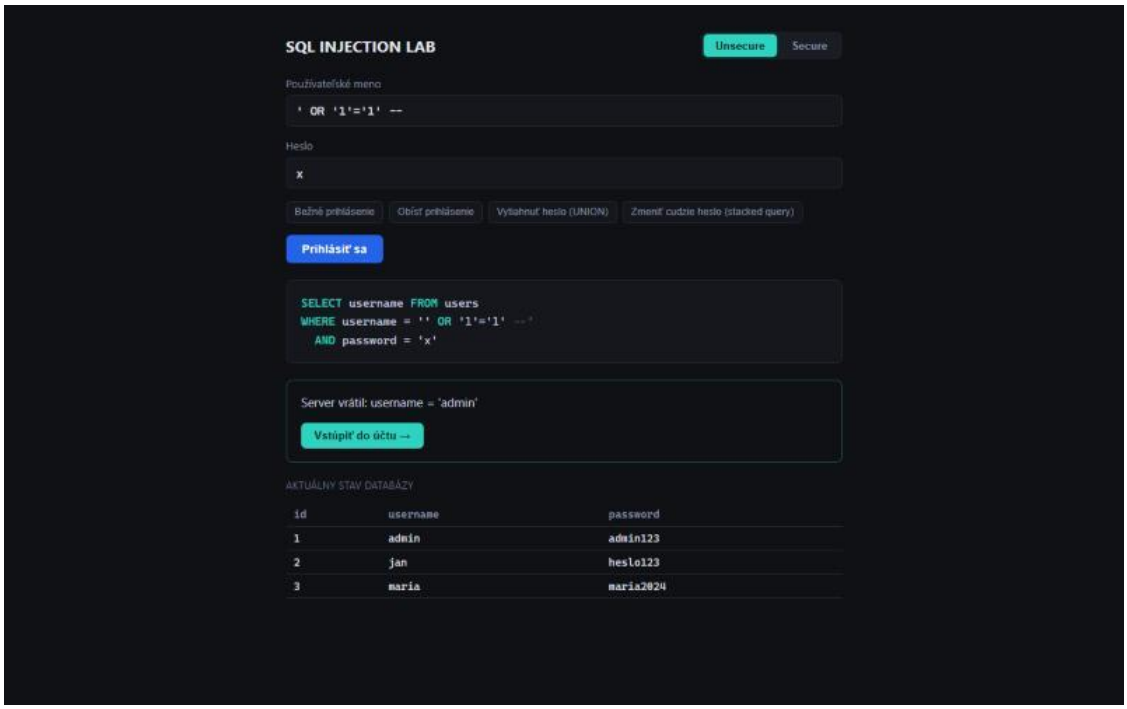
Najprv som vyskúšal normálne prihlásenie so správnym menom a heslom (admin / admin123), aby som overil, že aplikácia funguje ako ma.



Prihlásenie prebehlo normálne a server vrátil meno používateľa admin.

Obídenie prihlásenia (SQL injection)

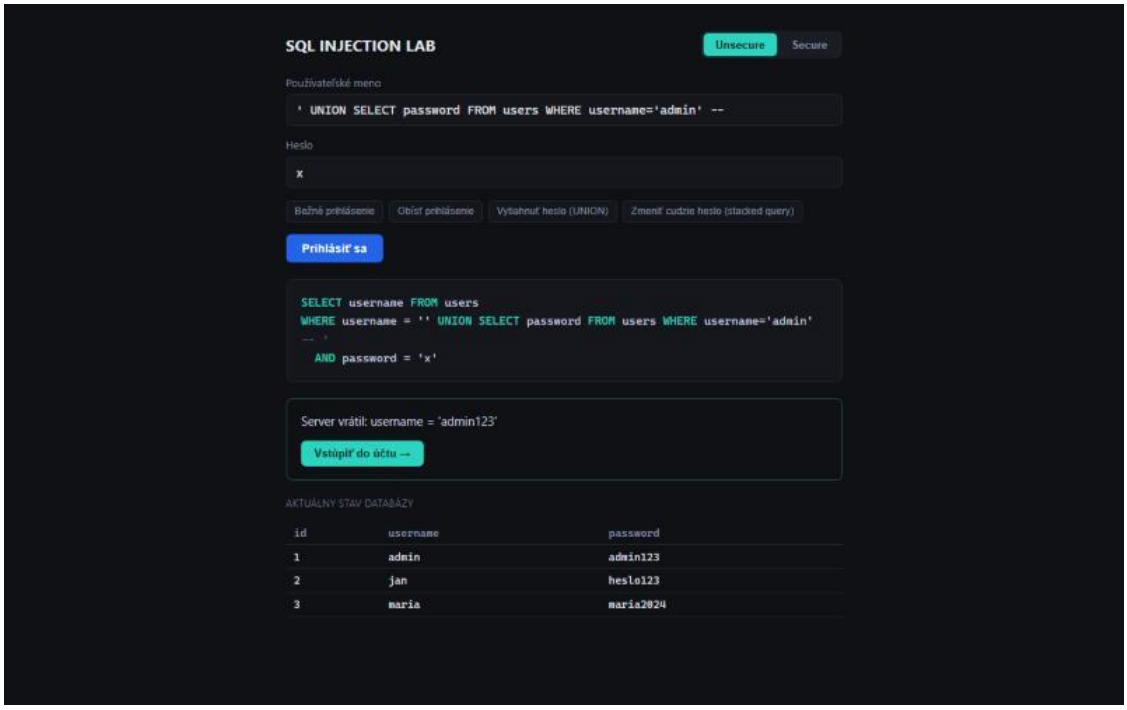
Potom som do poľa username zadal ' OR '1'='1' -- a do hesla ľubovoľný text. Keďže backend v unsecure režime vkladá vstup priamo do SQL dotazu, podmienka '1'='1' je vždy pravdivá a komentár -- zruší zvyšok dotazu aj s kontrolou hesla.



Server ma prihlásil ako admina, hoci som nezadal žiadne platné heslo - autentifikácia bola obídená.

Vytiahnutie cudzieho hesla cez UNION

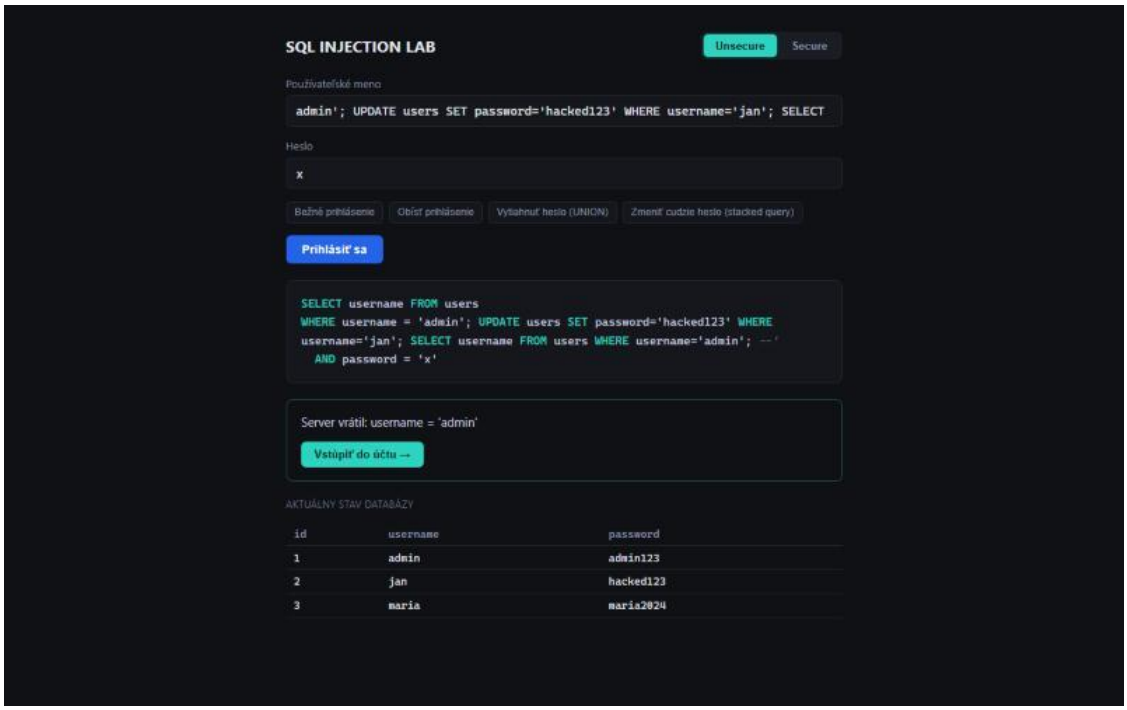
Ďalej som skúsil, či sa dá z dotazu vytiahnuť aj iná hodnota ako len username. Do poľa username som zadal ' UNION SELECT password FROM users WHERE username='admin' -- . Pôvodný dotaz tak vráti prázdny výsledok a UNION k nemu pripojí heslo používateľa admin.



Server vrátil username = 'admin123', čo je v skutočnosti heslo používateľa admin, nie meno. Takto sa dá cez login formulár vytiahnuť ľubovoľný stĺpec z tabuľky.

Zmena cudzieho hesla cez stacked query

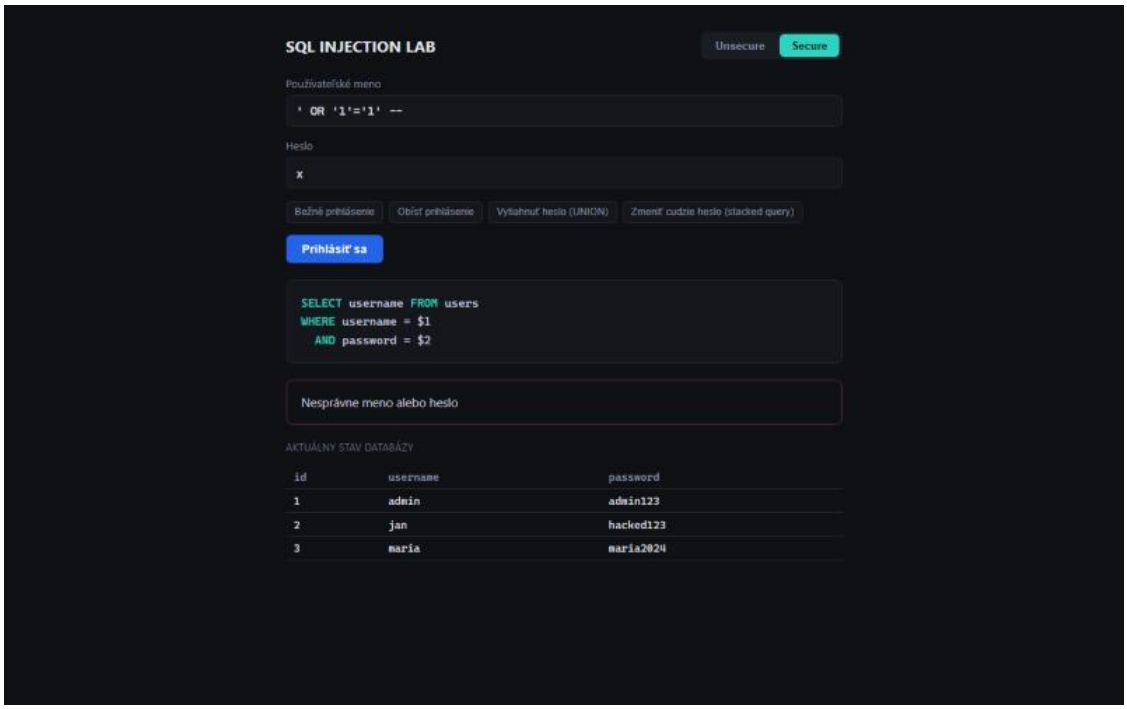
Nakoniec som vyskúšal stacked query, vloženie úplne nového SQL príkazu za pôvodný dotaz. Do username som zadal admin'; UPDATE users SET password='hacked123' WHERE username='jan'; SELECT username FROM users WHERE username='admin'; -- .



Prihlásenie prebehlo ako admin, formulár teda pôsobí úplne bežne. V tabuľke aktuálneho stavu databázy pod formulárom ale vidno, že sa potichu zmenilo heslo používateľa jan na hacked123, hoci ja som sa prihlasoval ako admin a o používateľovi jan som v hesle ani nehovoril.

Overenie v secure režime

Na záver som prepol prepínač na Secure a skúsil presne ten istý input ' OR '1'='1' -- ešte raz. V secure režime backend posiela username a password ako parametre ($1, $2), nie ako súčasť SQL reťazca.



Server tentoraz vrátil Nesprávne meno alebo heslo. Vstup sa zobral len ako obyčajný text a žiadna z predchádzajúcich techník nefungovala.